

ALFRED — Documentation Sécurité · Script · Rôle · Menace · Fichiers de suivi · Classe de risque				
Script / Fichier	Rôle	Menaces prises en charge	Fichiers de suivi	Classe de risque
PIPELINE D'ENTRÉE				
src/security/input_validator.py	Sanitisation de toutes les entrées utilisateur (normalisation unicode NFKC, null bytes, 25 patterns compilés)	SQL injection · XSS · Path traversal · Command injection · Prompt injection · SSRF · Homoglyphes · Null bytes	logs/security/security.log	CRITIQUE — OWASP A03
src/security/threat_detector.py	Score de menace sur chaque input (keywords + anomalies comportementales)	SQL tautologies · XSS · Command shells · Prompt jailbreak · LDAP injection · Null bytes · Encodage suspect	logs/security/audit_trail.jsonl	CRITIQUE — OWASP A03 · CWE-20
src/security/output_filter.py	Masquage des données sensibles dans les réponses générées	Fuite clés API · JWT · Tokens GitHub · Base64 sensible · Variables d'environnement	logs/security/security.log	ÉLEVÉ — OWASP A02
AUTHENTIFICATION ET CONTRÔLE D'ACCÈS				
src/auth/authenticator.py	Auth PIN locale · bcrypt rounds=12 · sel aléatoire 16 bytes · rate limiter intégré	Brute-force · Rainbow tables · Attaque dictionnaire · Réutilisation de hash	data/security/pins.json · logs/security/security.log	CRITIQUE — OWASP A07 · CWE-307
src/security/rate_limiter.py	Limitation de taux avec backoff exponentiel (30s→60s→120s) · fenêtre glissante 60s · thread-safe	Brute-force · Credential stuffing · Dénî de service local	logs/security/security.log	ÉLEVÉ — OWASP A04 · CWE-307
src/security/session_manager.py	Gestion cycle de vie des sessions (création, validité, fermeture, blocage)	Session hijacking · Session fixation · Réutilisation après expiration	Mémoire (migration SQLite prévue)	ÉLEVÉ — OWASP A07 · CWE-613
src/security/mfa_manager.py	Authentification multi-facteurs pondérée (face=3 · voix=2 · appareil=2 · PIN=1)	Usurpation d'identité · Compromission d'un seul facteur	config/security/security_settings.json	ÉLEVÉ — OWASP A07
src/security/access_control.py	Vérification des permissions par rôle (RBAC)	Escalade de privilèges · Accès non autorisé à des ressources	logs/security/security.log	CRITIQUE — OWASP A01
src/security/permission_manager.py	Matrice de permissions — 7 rôles de OWNER à EMERGENCY	Accès latéral · Privilege creep	config/security/roles_permissions.json	CRITIQUE — OWASP A01
POLITIQUE ZERO TRUST				

src/security/zero_trust_orchestrator.py	Orchestration 6 étapes : input → menace → appareil → accès → politique → audit · fail-secure	Toutes menaces combinées — aucune étape ne peut être contournée isolément	audit_trail.jsonl · security.log	CRITIQUE — Architecture ZT
src/security/policy_engine.py	Évaluation des règles (sensibilité ressource, action, rôle)	Accès ressources CRITICAL par rôles non autorisés · Actions destructives	config/security/zero_trust_rules.json	CRITIQUE — OWASP A01
src/security/policy_enforcement_point.py	Application de la décision PDP · Décisions inconnues → refus systématique (fail-secure)	Décisions ambiguës · Tentatives de contournement	logs/security/audit_trail.jsonl	ÉLEVÉ — CWE-636
src/security/device_registry.py	Registre des appareils de confiance · Vérification · Révocation · last_seen	Appareil non reconnu · Appareil compromis · Connexion depuis matériel inconnu	data/security/trusted_devices.json · security.log	ÉLEVÉ — OWASP A07 · CWE-287
CHIFFREMENT ET PROTECTION DES DONNÉES				
src/security/encryption_service.py	Chiffrement Fernet (AES-128-CBC + HMAC-SHA256) · IV aléatoire · Rotation de clé	Lecture données au repos · Exfiltration de fichiers · Falsification de tokens	Clé dans var. d'env. FERNET_KEY (.env exclu Git)	CRITIQUE — OWASP A02 · CWE-311
src/security/data_protection.py	Chiffrement sélectif des champs sensibles dans les JSON (password, token, api_key...)	Exposition de secrets dans fichiers de données utilisateur	logs/security/security.log	ÉLEVÉ — OWASP A02 · CWE-312
src/security/secret_manager.py	Validation des secrets critiques au démarrage (SECRET_KEY, FERNET_KEY, PIN_SALT)	Démarrage avec secrets par défaut · Secrets manquants	.env (exclu Git via .gitignore)	CRITIQUE — OWASP A05
src/security/backup_security.py	Vérification de l'intégrité des sauvegardes	Corruption de backup · Substitution de données · Restauration malveillante	À configurer	MOYEN — CWE-354
Détection et Réponse aux Incidents				
src/security/incident_manager.py	Enregistrement structuré des incidents (level, status, source, timestamp)	Traçabilité événements critiques · Gestion incidents ouverts	data/security/incident_register.json	ÉLEVÉ — OWASP A09
src/security/behavioral_detector.py	Détection d'anomalies comportementales (écart vs baseline + score)	Comportement anormal · Dérive de session · Usage atypique	Score en mémoire	MOYEN — CWE-754
src/security/prompt_guard.py	Protection contre les injections dans les chaînes LLM	Jailbreak · Extraction de contexte système · Manipulation du LLM	logs/security/security.log	ÉLEVÉ — Spécifique LLM

src/security/quarantine_service.py	Isolation des données suspectes	Contamination mémoire · Données corrompues ou malveillantes	À configurer	MOYEN — Architecture défensive
JOURNALISATION ET TRAÇABILITÉ				
src/security/audit_trail.py	Journal JSONL horodaté UTC · user · action · resource · decision	Non-répudiation · Investigation post-incident · Conformité GDPR	logs/security/audit_trail.jsonl	ÉLEVÉ — OWASP A09 · GDPR Art.30
src/security/security_logger.py	Logger dédié (INFO/WARNING/ERROR/CRITICAL) · log_access() · log_auth()	Traçabilité auth et accès	logs/security/security.log	ÉLEVÉ — OWASP A09
src/security/compliance_manager.py	Suivi de la conformité réglementaire	Non-conformité GDPR · Drift de configuration	config/security/audit_retention_policy.json	MOYEN — GDPR · ISO 27001
GOUVERNANCE ET MONITORING				
src/security/security_dashboard.py	Score sécurité 0-100 (grade A→F) · Conformité GDPR/OWASP · Résumé menaces/incidents · Rapport	Posture dégradée non détectée · Accumulation silencieuse de risques	audit_trail.jsonl · incident_register.json	Monitoring transverse
src/security/security_governance.py	13 contrôles durcissement · Matrice risques (likelihood × impact) · Reco CRITICAL→LOW	Dérives de configuration · Lacunes non traitées · Risques non prioritisés	Tous fichiers config sécurité	Gouvernance transverse

ALFRED — Suite de tests d'intrusion (136 tests · 100% pass)

Fichier test	Rôle	Vecteurs testés	Résultat	Classe de risque
tests/security/test_pentest_input.py	Tests d'intrusion — vecteurs d'injection	SQL (8 payloads) · XSS (8) · Path traversal (5) · Prompt injection (8) · Command injection (6) · Edge cases (8) = 43 tests	43/43 ☒	CRITIQUE — OWASP A03
tests/security/test_pentest_auth.py	Tests d'intrusion — authentification et rate limiting	Brute-force · Backoff exponentiel · Lockout · Isolation utilisateurs · Session lifecycle · PIN bcrypt = 20 tests	20/20 ☒	CRITIQUE — OWASP A07
tests/security/test_pentest_encryption.py	Tests d'intrusion — chiffrement Fernet et data_protection	Round-trip · IV aléatoire · Falsification token · Protection champs sensibles · Insensibilité casse = 16 tests	16/16 ☒	ÉLEVÉ — OWASP A02
tests/security/test_pentest_zero_trust.py	Tests d'intrusion — orchestrateur Zero Trust complet	Payloads malveillants → refus · Appareil inconnu → refus · Permission insuffisante · Ressource critique · Happy path = 13 tests	13/13 ☒	CRITIQUE — Architecture ZT
tests/security/test_pentest_dashboard_governance.py	Tests dashboard et gouvernance	Score/grade · Compliance structure · Matrice risques · Idempotence · Filtrage priorité = 44 tests	44/44 ☒	Monitoring

ALFRED — Points d'intégration sécurité dans main.py

Point d'intégration	Module appelé	Déclencheur	Effet sécurité	Classe de risque
main.py — démarrage	dotenv.load_dotenv()	Lancement ALFRED	Chargement FERNET_KEY et secrets depuis .env avant tout import	CRITIQUE — OWASP A05
main.py — démarrage	device_registry.init_default_device()	Lancement ALFRED	Enregistrement de l'appareil local dans le registre de confiance	ÉLEVÉ — OWASP A07
main.py — démarrage	audit_trail.write_audit_event()	Lancement ALFRED	Événement STARTUP tracé dans audit_trail.jsonl	ÉLEVÉ — OWASP A09
main.py — boucle principale	input_validator.sanitize_input()	Chaque saisie utilisateur	Rejet des inputs malveillants (25 patterns, unicode, null bytes)	CRITIQUE — OWASP A03
main.py — boucle principale	threat_detector.detect_threat()	Après sanitisation	Blocage si score de menace ≥ 3 + message utilisateur + audit	CRITIQUE — OWASP A03
main.py — boucle principale	output_filter.filter_output()	Chaque réponse générée	Masquage clés/tokens avant affichage, TTS et stockage mémoire	ÉLEVÉ — OWASP A02
main.py — boucle principale	audit_trail.write_audit_event()	Chaque échange	Trace CONVERSATION/ALLOW dans audit_trail.jsonl	ÉLEVÉ — OWASP A09
main.py — commande 'reset'	audit_trail.write_audit_event()	Commande de suppression mémoire	Trace DELETE_DATA/session_memory dans l'audit trail	ÉLEVÉ — OWASP A09
main.py — fallback dégradé	_SECURITY_AVAILABLE flag	Si imports sécurité échouent	Sanitisation basique active, ALFRED continue sans planter	MOYEN — Résilience

ALFRED — Synthèse conformité OWASP Top 10

Classe OWASP	Titre	Modules couvrants	Statut
A01 — Contrôle d'accès	Broken Access Control	access_control · permission_manager · role_manager · policy_engine · zero_trust_orchestrator · roles_permissions.json	✓ Couvert
A02 — Exposition données	Cryptographic Failures	encryption_service · data_protection · output_filter · secret_manager	✓ Couvert
A03 — Injection	Injection	input_validator (25 patterns) · threat_detector · prompt_guard	✓ Couvert
A04 — Design non sécurisé	Insecure Design	rate_limiter (backoff) · policy_enforcement_point (fail-secure) · zero_trust_orchestrator	✓ Couvert
A05 — Mauvaise configuration	Security Misconfiguration	secret_manager · security_governance (13 contrôles) · roles_permissions.json · zero_trust_rules.json	✓ Couvert
A06 — Composants vulnérables	Vulnerable Components	pip-audit (prévu en CI) · requirements.txt	⚠ Partiel
A07 — Auth et identification	Auth Failures	authenticator (bcrypt) · session_manager · mfa_manager · device_registry · rate_limiter	✓ Couvert
A08 — Intégrité logicielle	Software Integrity Failures	backup_security	⚠ À compléter

A09 — Logging et monitoring	Security Logging Failures	audit_trail · security_logger · incident_manager · security_dashboard	☒ Couvert
A10 — SSRF	Server-Side Request Forgery	input_validator (patterns localhost / ldap:// / gopher://)	☒ Couvert

ALFRED — Fichiers de configuration sécurité				
Fichier	Contenu	Menaces prises en charge	Utilisé par	Classe de risque
config/security/roles_permissions.json	Matrice RBAC — 7 rôles · permissions · MFA requis · timeout session	Escalade de privilèges · Accès non autorisé	permission_manager.py · access_control.py	CRITIQUE — OWASP A01
config/security/zero_trust_rules.json	8 règles Zero Trust (ZT-001→ZT-007 + DEFAULT)	Accès ressources critiques · Actions destructives non autorisées	policy_engine.py	CRITIQUE — Architecture ZT
config/security/security_settings.json	Méthode de chiffrement · MFA requis (true)	MFA contourné · Chiffrement faible	mfa_manager.py	ÉLEVÉ — OWASP A05
config/security/audit_retention_policy.json	Politique de rétention des logs d'audit	Suppression non autorisée de journaux · Non-conformité GDPR	compliance_manager.py	MOYEN — GDPR Art.5
config/security/trusted_devices.json	Configuration initiale du registre d'appareils	Appareils non autorisés	device_registry.py	ÉLEVÉ — OWASP A07
.env (exclu de Git)	FERNET_KEY · SECRET_KEY · PIN_SALT · SESSION_TIMEOUT · MAX_LOGIN_ATTEMPTS	Exposition de secrets · Démarrage non sécurisé	encryption_service.py · secret_manager.py · authenticator.py	CRITIQUE — OWASP A05
.gitignore	Exclusions : .env · *.key · *.pem · data/security/pins.json	Commit accidentel de secrets · Exposition dans l'historique Git	Git	CRITIQUE — OWASP A05